



LE PARTENAIRE INFORMATIQUE DU PROGRÈS
EN FÉDÉRATION WALLONIE-BRUXELLES

L'IT pour et par l'Humain.

LE VADE MECUM

ETNIC
de la sécurité
de l'information

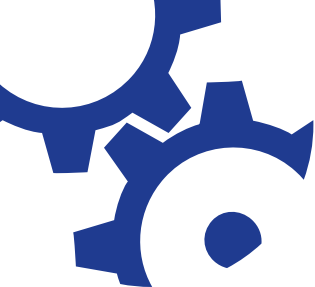


Table des matières

Le Vade Mecum ETNIC de la sécurité de l'information

Les 5 piliers documentaires et de conformité	4
La Directive NIS2	4
La norme ISO 27001	4
Le Roadbook sécurité l'ETNIC	4
La politique Générale de Sécurité de l'ETNIC	5
Le socle de sécurité de l'ETNIC	5
Les critères indispensables dans le cadre d'un projet	6
L'analyse des risques SPOTool	10
De quoi parle-t-on ?	10
Comment demander une analyse ?	10
Le socle de sécurité ETNIC du système d'information	12
Pilier 1 - Continuité et Reprise	12
Disposer d'un Recovery Time Objective (RTO)	12
Disposer d'un Recovery Point Objective (RPO)	12
Disposer de la criticité des actifs	12
Mettre en place une résilience organisationnelle	12
Pilier 2 - Traçabilité transversale	14
Gestion des traces applicatives	14
Gestion des traces techniques	14
SIEM	14
SOAR	14
SOC	14

Pilier 3 - Garantir la sécurité des activités cloud	15
Contrôle des dépendances et sous-traitants cloud	15
Application des exigences de sécurité	15
Pilier 4 - Garantir un processus fiable d'identification et d'authentification	15
MFA	15
IAM	15
FIDO2	16
Pilier 5 - Garantir la maîtrise des risques du SI	16
SPOTool sur les projets critiques	16
Tests d'intrusion pour les projets critiques	16
Gestion des vulnérabilités techniques	16
Audit du code source pour l'ensemble des applications développées	16
Approche Otrust	17
Fonctionnement du SMSI de l'ETNIC	18

Manuel à garder à sa portée pour consultation fréquente ; dans le cadre d'un projet, de questionnements, d'un contact avec un bénéficiaire, de l'estimation des enjeux de sécurité, de prospective... d'un projet ou d'un service porté par l'ETNIC.

Les 5 piliers documentaires et de conformité

La Directive NIS2

La Directive NIS2, adoptée par l'Union Européenne et transposée dans la loi belge, vise à renforcer la cybersécurité des réseaux et systèmes d'information essentiels. Elle impose des obligations strictes aux entités opérant dans les secteurs critiques, tels que l'énergie, les transports, la santé et les infrastructures numériques, dont fait partie l'ETNIC. La Directive impose notamment d'implémenter des mesures de sécurité pour prévenir et gérer les incidents de cybersécurité. Cela inclut l'évaluation régulière des risques, la mise en place de politiques de sécurité et la maîtrise de ses actifs. La Directive NIS2 introduit également des sanctions plus sévères pour non-conformité, encourageant ainsi les organisations à adopter une approche proactive en matière de cybersécurité.

- [Texte de la Directive EU](#)

La norme ISO 27001

La norme ISO 27001 est un standard international pour la gestion de la sécurité de l'information, visant à protéger les données sensibles contre les menaces. Elle nécessite la mise en place d'un Système de Management de la Sécurité de l'Information (SMSI) pour identifier, évaluer et traiter les risques. L'ETNIC a adopté cette norme et dispose de son propre SMSI. Une attention particulière est portée à la gestion des actifs, le contrôle d'accès ou encore la gestion des incidents. L'audit interne régulé et l'amélioration continue sont des éléments clés pour garantir la conformité. La certification ISO 27001, délivrée après un audit externe, atteste de la capacité de l'entreprise à protéger ses informations. L'ETNIC s'inscrit dans une démarche de certification ISO 27001 en débutant par le service IAM.

- La norme est intégrée dans le cadre du SMSI de l'ETNIC (Système de management de la sécurité de l'information) traduite dans le cadre de nos politiques de sécurité qui sont disponibles sur [cette page de l'intranet et est représenté dans son fonctionnement général à la page 16 de ce manuel](#).

Le Roadbook sécurité l'ETNIC

L'ETNIC vise quatre objectifs principaux avec ce Roadbook : définir sa vision en matière de sécurité de l'information et de protection des données personnelles ; communiquer de manière transparente la stratégie mise en place pour réaliser cette vision ; documenter les objectifs et les mesures soutenant cette stratégie ; et décrire l'existant ainsi que les principales mesures déjà déployées ou amorcées. Ce document s'adresse principalement aux bénéficiaires et aux personnes en charge de la stratégie à l'ETNIC.

- [Télécharger le Roadbook](#)
- [Lire en ligne le Roadbook](#)

La politique Générale de Sécurité de l'ETNIC

La politique de sécurité de l'ETNIC définit les lignes directrices pour protéger les informations sensibles et les ressources de l'ETNIC. Elle précise les objectifs de sécurité, les rôles et responsabilités ainsi que les procédures à suivre pour garantir la sécurité des données. Les politiques sont déclinées sous la forme de politiques spécifiques qui concernent des domaines sous-jacents.

- [Ensemble des politiques de sécurité de l'ETNIC](#)

Le socle de sécurité de l'ETNIC

Un « socle de sécurité » est un ensemble de mesures **non négociables** visant à protéger le système d'information de l'ETNIC et de ses bénéficiaires. Parmi ces mesures figurent l'authentification multi-facteur, le contrôle d'accès strict, ou encore la gestion des correctifs pour maintenir les logiciels à jour. Progressivement, l'ETNIC se positionne sur ces mesures non négociables qui représentent de véritables protections pour garantir un niveau de sécurité acceptable ou pour répondre à certaines Directives et normes liées à la criticité des données traitées comme la santé et la justice.

- Le socle est détaillé au [point 6](#) de ce document.

Les critères indispensables dans le cadre d'un projet

L'ETNIC utilise une méthodologie d'analyse des risques adaptée à son contexte de sous-traitant IT appelée SPOTool. Cet outil permet d'évaluer le niveau d'exigence de sécurité et les mesures associées pour un projet ou un service. Cependant, en raison de ressources limitées, il n'est pas possible de réaliser ces analyses pour chaque projet. Les questions suivantes permettent à toute personne, qu'il s'agisse d'un chef de projet, d'un consultant ou d'un bénéficiaire, d'identifier les questions clés à se poser dans le cadre de la conduite du projet. Ce questionnaire s'inscrit également dans le cadre d'exigences sécurité et de contrôles de conformité dans la gestion des projets de l'ETNIC.

SEC - Q1

Le dossier d'architecture (DA) est-il présent et à jour, il doit contenir notamment les flux de données entre les applications/solutions et leurs moyens d'intégration ?

- ☒ Le dossier d'architecture (Solution & Infra) doit indiquer l'ensemble des prescriptions architecturales (contraintes) pour permettre le déploiement et l'intégration de l'application (livrable) sur les environnements du Système d'Information.
- ☐ Si ce n'est pas le cas, il est indispensable de demander et de bénéficier de ce livrable. Sans ce document d'architecture, la mise en production du service ou du projet pourra ne pas être acceptée.

SEC - Q2

Le dossier Identité et Autorisation est-il complet dans le cadre IAM ?

- ☒ La gestion des identités et des accès (IAM, pour Identity and Access Management) est un cadre obligatoire pour assurer la sécurité des informations et l'accès approprié aux ressources dans une organisation. Identifier et définir les profils applicatifs, identifier les éventuels paramètres de ces profils, décrire les règles d'attribution et de révocation. Cette analyse est indispensable.
- ☐ Si ce n'est pas le cas, il est indispensable de demander et de bénéficier de ce livrable. Sans ce document, la mise en production du service ou du projet pourra ne pas être acceptée.

SEC - Q3

Le projet implémente-t-il une authentification forte de type MFA ?

- ☒ L'authentification multi-facteurs (MFA) est une méthode de vérification renforcée qui exige de l'utilisateur qu'il présente au moins deux preuves (facteurs ou protocoles de type FIDO2 passwordless) d'authentification avant de lui accorder l'accès au Système d'Information. Cette mesure est rendue obligatoire par une Directive Belge de sécurité à destination des administrations depuis le 01 janvier 2024.
- ☐ Si ce n'est pas le cas, il est indispensable de demander et de bénéficier de cette mesure. La mise en production du service ou du projet pourra ne pas être acceptée. Dans le cas contraire, le métier doit avoir marqué par écrit sa connaissance du risque et sa prise de responsabilité face à l'absence de cette mesure.

SEC - Q4

Est-ce qu'il existe une matrice de traçabilité à jour ?

- ☒ Il s'agit d'une grille ou d'un tableau qui associe les actions des utilisateurs aux résultats attendus ou observés dans le système. Cette matrice identifie clairement les traces à garder et la durée de rétention de celles-ci. Cette matrice de traçabilité est construite en collaboration avec le métier.
- ☐ Si ce n'est pas le cas, il est indispensable de demander et de bénéficier de cette mesure. La mise en production du service ou du projet pourra ne pas être acceptée.

SEC - Q5

Les parties prenantes du projet sont-elles documentées et contrôlées ?

- ☒ Les personnes travaillant sur le projet doivent être identifiées et listées (développeurs, techniciens, analystes, chef de projet) et maintenues à jour. La liste des sous-traitants doit être maintenue et documentée dans le cadre du projet. Un contrôle trimestriel de la liste doit être effectué.
- ☐ Si ce n'est pas le cas, il est indispensable de réaliser ce livrable. La mise en production du service ou du projet pourra ne pas être acceptée.

SEC - Q6

Le code source est-il correctement documenté ?

- ☒ Le maintien à jour d'une liste des librairies et Framework est essentiel pour un projet de développement logiciel. Cette pratique consiste à tenir une documentation régulièrement révisée qui répertorie les librairies et les Framework utilisés dans les projets de développement, incluant les versions actuelles, les mises à jour disponibles, et les informations pertinentes sur la sécurité et la compatibilité. Le code source est maintenu documenté et peut être transmis à toute personne qualifiée en l'état.
- ☐ Si ce n'est pas le cas, il est indispensable de prendre les mesures nécessaires pour y parvenir et de sensibiliser les personnes dans le projet. La mise en production du service ou du projet pourra ne pas être acceptée.

SEC - Q7

L'ensemble des composants IT et leurs relations, constitutifs de l'architecture technique sont-ils documentés sous la forme d'une liste d'actifs à jour ?

- ☒ La documentation de tous les composants IT et de leurs relations sous forme d'une liste d'actifs est cruciale pour garantir une gestion efficace et sécurisée de l'architecture technique. Elle permet de visualiser l'ensemble des actifs, d'identifier les interdépendances, de faciliter les audits et de gérer les risques.
- ☐ Sans cette documentation, il ne sera pas possible de déployer des mesures de protection techniques dans le cadre de la sécurité. La connaissance des composants et actifs est indispensable pour analyser les risques et protections à mettre en place par les équipes de sécurité.

SEC - Q8

Une analyse des risques relative aux vulnérabilités techniques en sécurité est-elle réalisée et maîtrisée ?

- ☒ Une analyse des risques relative aux vulnérabilités techniques doit être demandée au service SSI. L'essentiel des vulnérabilités du projet doivent être traitées. Si certaines vulnérabilités ne sont pas liées aux projets elles doivent être remontées aux parties prenantes notamment à travers le processus de gestion des vulnérabilités ETNIC (*Vulnerability Response* dans ServiceNow).
- ☐ Sans un audit positif des vulnérabilités techniques (vulnérabilités critiques mitigées), la mise en production du projet pourra ne pas être acceptée.

SEC - Q9

Un audit du code applicatif a-t-il été réalisé ?

- ☒ Il est indispensable que le code source du projet soit audité par l'intermédiaire de l'outil SonarCube interne à l'ETNIC. L'objectif est non seulement d'identifier les potentielles vulnérabilités et erreurs de codage mais aussi d'encourager une culture de l'excellence et de l'amélioration continue au sein des équipes. Les critères minimums à respecter sont le TOP10 OWASP et SANS TOP25.
- ☐ Un projet ne peut pas être déployé en production sans un audit de code préalable.

SEC - Q10

Si le projet contient des données sensibles*, un test d'intrusion est nécessaire.

- ☒ Le test d'intrusion permet d'identifier et de corriger les vulnérabilités de sécurité avant qu'elles ne soient exploitées par des attaquants, contribuant ainsi à la protection des données sensibles et à la préservation de la réputation de l'ETNIC. Une demande peut être faite à spot@etnic.be qui analysera la nécessité ou non de mener le test d'intrusion.

* Définition de donnée sensible : les données sensibles sont des informations personnelles révélant des aspects comme l'origine raciale, les opinions politiques, ou la santé. Leur traitement exige des protections renforcées pour préserver les droits et libertés des personnes concernées.

L'analyse des risques SPOTool

De quoi parle-t-on ?

L'équipe SPOT dispose d'un outil maison permettant d'analyser les risques en sécurité de l'information des différents projets développés en interne. Cet outil doit permettre d'assurer un contrôle et un suivi de l'implémentation de la sécurité dans les projets développés ou déployés par l'ETNIC et de supporter directement le principe de « By Design » & « By Default ». L'outil repose directement sur l'ISO27005 et l'ISO27002.

Comment demander une analyse ?

Il est indispensable de remplir d'abord le questionnaire et de nous le faire parvenir. En fonction des réponses et de la criticité du projet, nous évaluerons les ressources disponibles et déterminerons la nécessité de conduire une analyse. L'adresse de contact est spot@etnic.be

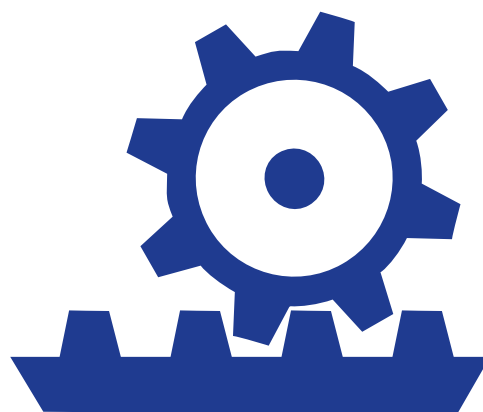


Illustration d'une analyse des risques SPOTool



Actuellement le positionnement de SPOT sur le projet Entrer ici le nom de l'application est : Avis favorable moyennant un traitement des risques identifiés



Pour toute question sur l'outil, merci de contacter spot@etnic.be

Introduction

L'équipe SPOT a rédigé en 2022 un roadbook sécurité définissant la vision de l'ETNIC en sécurité de l'information et la stratégie pour y parvenir. Cet outil s'inscrit dans cette stratégie pour assurer un suivi *By Design* et *By Default* des différents projets menés par l'ETNIC avec ses bénéficiaires. Cette analyse est toujours réalisée par un membre de l'équipe SPOT qui détient une certification ISO27001 & ISO27005.

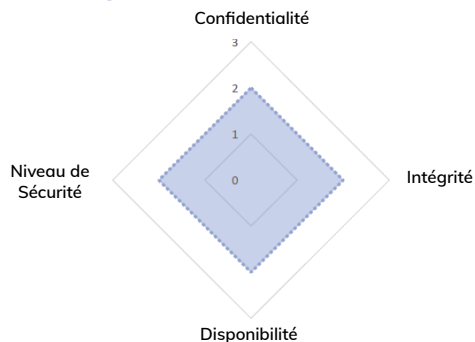
Objectifs de l'outil

- Assurer une homogénéité et **une cohérence dans l'évaluation de la sécurité** dans les différents projets
- Garantir **une approche pragmatique** et réaliste **adaptée à l'ETNIC**
- Définir **un indice de maturité par projet** et un **cadastre global** de suivi des projets
- Amorcer **la construction d'un socle de sécurité** à partir des pratiques du terrain

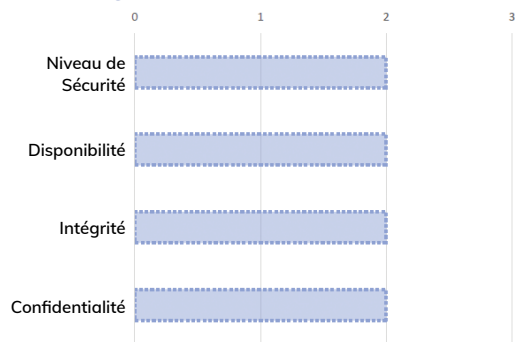
Finalités de l'outil

- Evaluer le risque inhérent dans le projet
- Evaluer les mesures mises en place pour déterminer le risque résiduel
- Permettre à l'équipe SPOT d'identifier plus rapidement les enjeux et problématiques potentielles
- Garantir la production de recommandations fiables et alignées aux politiques de sécurité
- Garantir une approche standardisée des analyses de sécurité et des risques à l'ETNIC

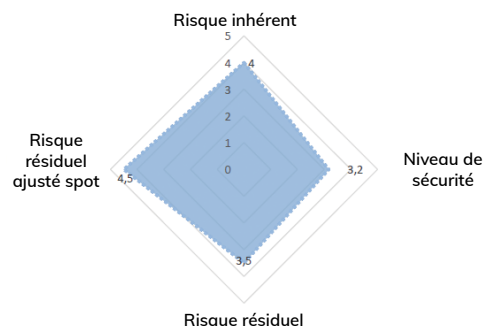
Classification de l'actif



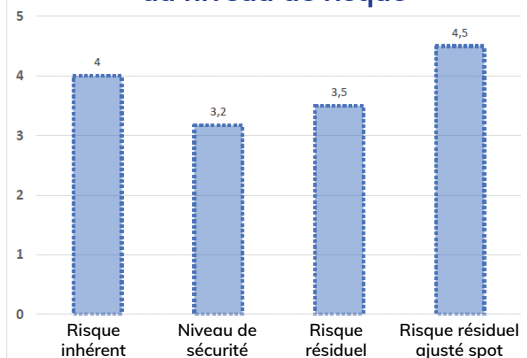
Classification de l'actif



Résultat analyse du niveau de risque



Résultat analyse du niveau de risque



Classification



Le socle de sécurité ETNIC du système d'information

La conduite d'un socle de sécurité est indispensable pour garantir à nos bénéficiaires un niveau adéquat de maturité en sécurité dans les différents projets. L'intérêt d'un socle de sécurité est d'identifier les mesures transversales réellement garanties par l'ETNIC.

Le socle de sécurité est intimement lié au SMSI mais également aux politiques de sécurité. Les politiques de sécurité de l'ETNIC définissent la direction à prendre mais pas la manière de s'y rendre. Le socle de sécurité reprend les mesures appliquées et contrôlées permettant de rencontrer la politique de sécurité et ses politiques spécifiques.

Les 5 premières exigences du socle de sécurité V1 sont reprises ci-dessous et représentent les actions reconnues **comme indispensables, systématiques et obligatoires à déployer par l'ETNIC pour l'ensemble de ses bénéficiaires dans le cadre du mandat 2025-2029.**

Pilier 1 - Continuité et Reprise

Disposer d'un Recovery Time Objective (RTO)

Représente le temps maximum acceptable pour restaurer un système après une interruption, indicateur déterminant pour minimiser l'impact opérationnel.

Disposer d'un Recovery Point Objective (RPO)

Détermine la quantité de données que l'organisation peut se permettre de perdre en cas d'incident, guidant la fréquence des sauvegardes pour assurer une reprise rapide. La criticité des actifs consiste à évaluer l'importance des systèmes et données pour les opérations, permettant de prioriser les efforts de reprise en cas de sinistre dans le cadre d'un *Disaster Recovery Plan* (DRP). La gestion des crises liées aux incidents de sécurité englobe les procédures et actions mises en place pour répondre efficacement aux situations d'urgence, assurant une communication rapide, des ressources disponibles, et des décisions pour limiter les dommages et restaurer les activités normales. Ensemble, ces éléments constituent un cadre essentiel pour la continuité des activités et **la résilience organisationnelle.**

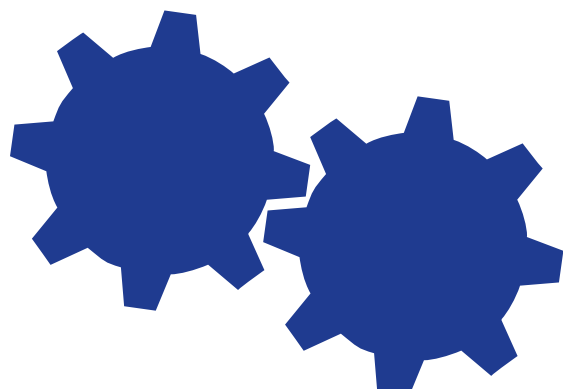
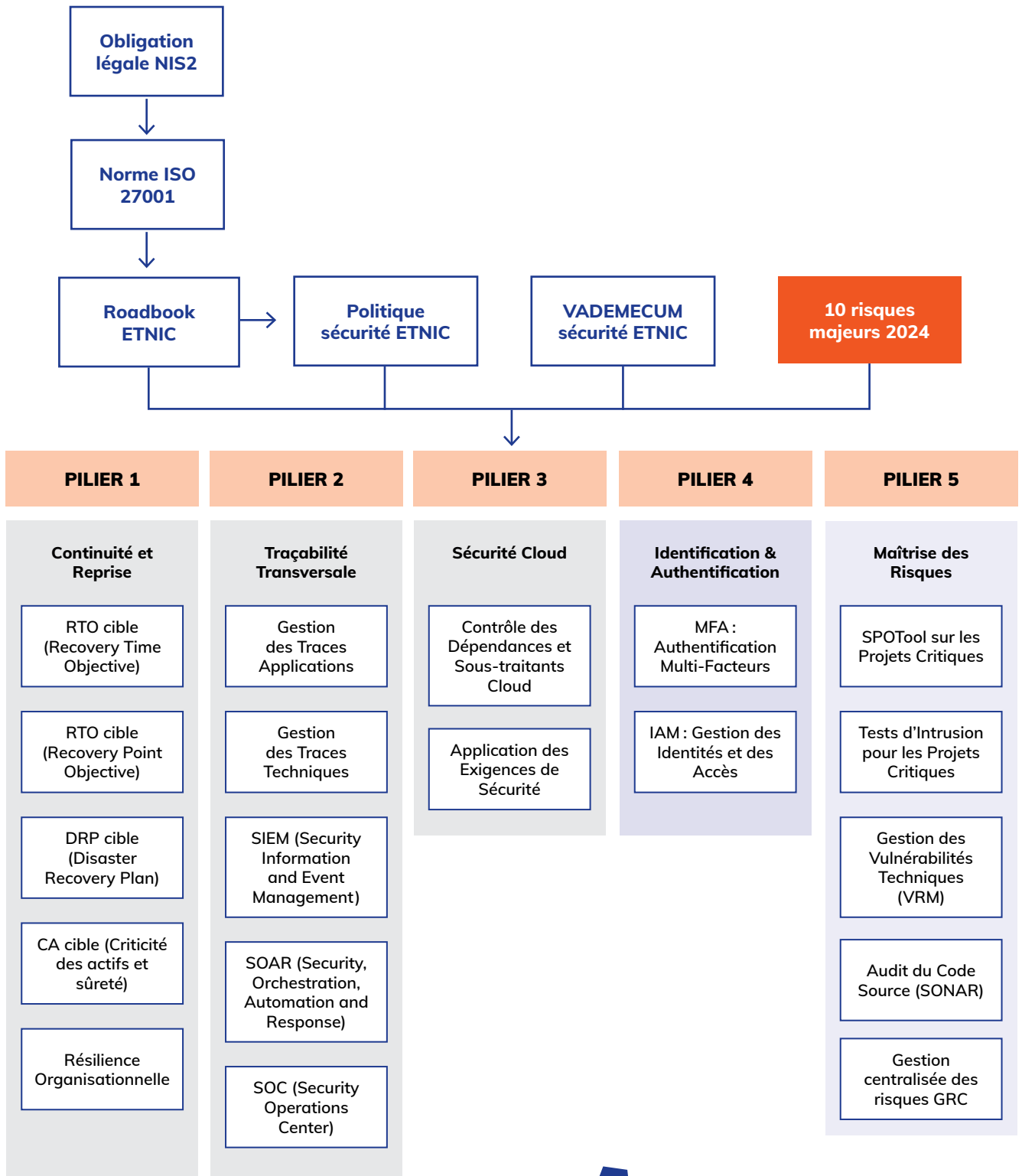
Disposer de la criticité des actifs

Définir et établir la criticité des actifs en lien avec les activités métier.

Mettre en place une résilience organisationnelle

Mise en œuvre d'un système de gestion de la résilience organisationnelle (ISO 22316) validé par le CODIR ETNIC en décembre 2023, incluant l'implémentation du COSO Enterprise Risk Management. Cela exige la mise en place d'un système de gestion de la continuité d'activité (BCMS ISO 22301) et d'un système de gestion de crise en cours d'implémentation à l'ETNIC conformément à l'ISO 22361.

Socle Sécurité du SI – ETNIC



Pilier 2 - Traçabilité transversale

La gestion des traces applicatives implique la collecte et l'analyse des logs générés par les applications pour garantir le bon fonctionnement et la conformité. La gestion des traces techniques concerne le suivi des logs des composants techniques de l'infrastructure IT, offrant une vue détaillée sur les performances et les éventuelles défaillances. Le SIEM (Security Information and Event Management) centralise et analyse ces logs de sécurité pour détecter et répondre aux incidents en temps réel. Le SOAR (Security Orchestration, Automation, and Response) automatise les réponses aux menaces et incidents de sécurité, augmentant ainsi l'efficacité des opérations de sécurité. Le SOC (Security Operations Center) est une équipe dédiée à la surveillance continue, à la détection et à la réponse aux menaces de sécurité, garantissant la protection des actifs informatiques. Ensemble, ces éléments constituent une infrastructure complète pour la gestion de la traçabilité du système d'information.

Gestion des traces applicatives

La gestion des traces applicatives consiste à collecter, stocker et analyser les journaux d'activité des applications pour surveiller leur fonctionnement, détecter des anomalies et assurer la sécurité dans le contexte métier de l'application. Elle permet de retracer les actions des utilisateurs et des systèmes pour faciliter la résolution des incidents et la conformité réglementaire.

Gestion des traces techniques

La gestion des traces techniques implique la collecte, le stockage et l'analyse des journaux techniques des systèmes informatiques pour surveiller leur performance, détecter des anomalies et assurer la sécurité. Elle permet de retracer les événements et activités techniques pour faciliter la résolution des incidents et la conformité réglementaire.

SIEM

Un SIEM (*Security Information and Event Management*) est un système qui collecte, analyse et corrèle les données de sécurité provenant de diverses sources pour détecter et répondre aux menaces en temps réel. Il centralise la gestion des incidents de sécurité et facilite la conformité réglementaire.

SOAR

Un SOAR (*Security Orchestration, Automation, and Response*) est un système qui intègre et automatise les outils et processus de sécurité pour répondre aux incidents plus rapidement et efficacement. Il centralise la gestion des menaces, permet l'orchestration des tâches et améliore la collaboration entre les équipes de sécurité.

SOC

Un SOC (*Security Operations Center*) est une équipe centralisée de spécialistes en sécurité chargée de surveiller, détecter et répondre aux incidents de sécurité en temps réel. Le centre d'opération utilise des outils et des processus automatisés pour protéger les systèmes et analyser les menaces participant également à la gestion des crises et à la résilience de l'organisme.

Pilier 3 - Garantir la sécurité des activités cloud

Garantir la maîtrise de la sécurité des activités cloud implique une gestion rigoureuse des dépendances et des sous-traitants, notamment en s'assurant que chaque fournisseur respecte les exigences de sécurité. Ce contrôle commence dès l'élaboration des marchés publics, qui doivent contenir les exigences nécessaires en matière de sécurité ainsi que des clauses permettant de vérifier le respect de ces exigences. Le respect de ces exigences doit également faire partie des critères d'attribution. Les contrôles réguliers et les audits sont essentiels pour vérifier la conformité aux standards et détecter les vulnérabilités potentielles. Ces audits permettent d'évaluer l'efficacité des mesures de sécurité en place et de s'assurer que les pratiques des sous-traitants sont alignées avec les politiques de l'ETNIC. Ensemble, ces pratiques assurent une surveillance continue et proactive des environnements cloud, garantissant ainsi la sécurité, la performance et la résilience des services cloud.

Contrôle des dépendances et sous-traitants cloud

Évaluation des fournisseurs de services cloud, clauses de sécurité spécifiques dans les contrats et mise en place de mécanismes de suivi et d'audit réguliers pour garantir la conformité et la sécurité des données et des systèmes hébergés.

Application des exigences de sécurité

Mettre en œuvre et appliquer la politique spécifique cloud de l'ETNIC pour l'ensemble des parties prenantes relatives au cloud.

Pilier 4 - Garantir un processus fiable d'identification et d'authentification

Garantir une identification et une authentification robustes implique l'implémentation de l'authentification multi-facteurs (MFA), qui ajoute une couche de sécurité supplémentaire en nécessitant plusieurs formes de facteurs d'authentification. La gestion des identités et des accès (IAM) joue un rôle central en contrôlant l'accès aux ressources de l'ETNIC. Ensemble, l'authentification multi-facteurs et la gestion des identités renforcent la sécurité des systèmes en réduisant les risques d'accès non autorisé.

MFA

L'authentification multi-facteurs (MFA) ajoute une couche de sécurité supplémentaire en exigeant plusieurs formes de preuves d'authentification pour accéder aux systèmes. Protection rendue obligatoire depuis le 1er janvier 2024 par l'autorité belge.

IAM

La gestion des identités et des accès (IAM) est une composante essentielle et déterminante dans la protection du SI. L'ETNIC bénéficie d'une maturité importante dans ce domaine qui doit être encore renforcée dans le cadre de l'obtention d'une certification 27001.

FIDO2

FIDO2 est un ensemble de normes d'authentification développées par l'Alliance FIDO en collaboration avec le W3C, publié officiellement en mars 2024. Il vise à remplacer les mots de passe traditionnels par des méthodes d'authentification plus sécurisées et conviviales dites «PasswordLess», comme les données biométriques ou les clés de sécurité matérielles. Déjà implémenté à l'ETNIC dans le cadre de l'offre MFA, FIDO2 renforce la sécurité des accès internes. L'intérêt principal de FIDO2 réside dans sa capacité à offrir une authentification forte sans nécessiter de mots de passe, réduisant ainsi les risques liés au phishing et au vol d'identifiants. En termes de capacités d'authentification, FIDO2 permet une authentification multifacteur intégrée et une expérience utilisateur simplifiée. Il supporte le protocole WebAuthn, facilitant l'intégration de ces méthodes dans les navigateurs web et les applications. Ainsi, FIDO2 représente une avancée significative vers un environnement numérique plus sûr et plus efficace, déjà adopté par l'ETNIC pour améliorer la sécurité de ses services.

Pilier 5 - Garantir la maîtrise des risques du SI

Les audits et contrôles des risques et vulnérabilités sont essentiels pour assurer la sécurité des systèmes. Les analyses SPOTool sur les projets critiques permettent d'évaluer les risques spécifiques et d'identifier les mesures à déployer. Les évaluations techniques permettent d'identifier et de mesurer les vulnérabilités présentes sur les systèmes.

SPOTool sur les projets critiques

Conduite d'analyse des risques sur les projets critiques pour le métier et/ou l'ETNIC ou reprenant des données sensibles. Les évaluations sont conduites en fonction des ressources disponibles. Les chefs de projets disposent d'une grille de contrôle sous la forme d'un questionnaire permettant d'identifier les exigences minimales à rencontrer dans les projets.

Tests d'intrusion pour les projets critiques

Les tests d'intrusion sont réalisés sur base de l'intérêt que comporte ces audits et de la criticité du projet. Ils sont demandés par les chefs de projets et décidés de réalisation ou non par l'équipe SPOT.

Gestion des vulnérabilités techniques

Un processus de gestion des vulnérabilités est en production à l'ETNIC. Celui-ci demande un suivi transversal à l'ETNIC et un état des lieux périodique pour garantir une augmentation constante de la réduction des vulnérabilités sur le système d'information.

Audit du code source pour l'ensemble des applications développées

Les applications développées en interne doivent être auditées au niveau du code source. L'outil SONAR est utilisé et doit intégrer des critères et exigences minimales à respecter dans chaque projet.

Approche Otrust

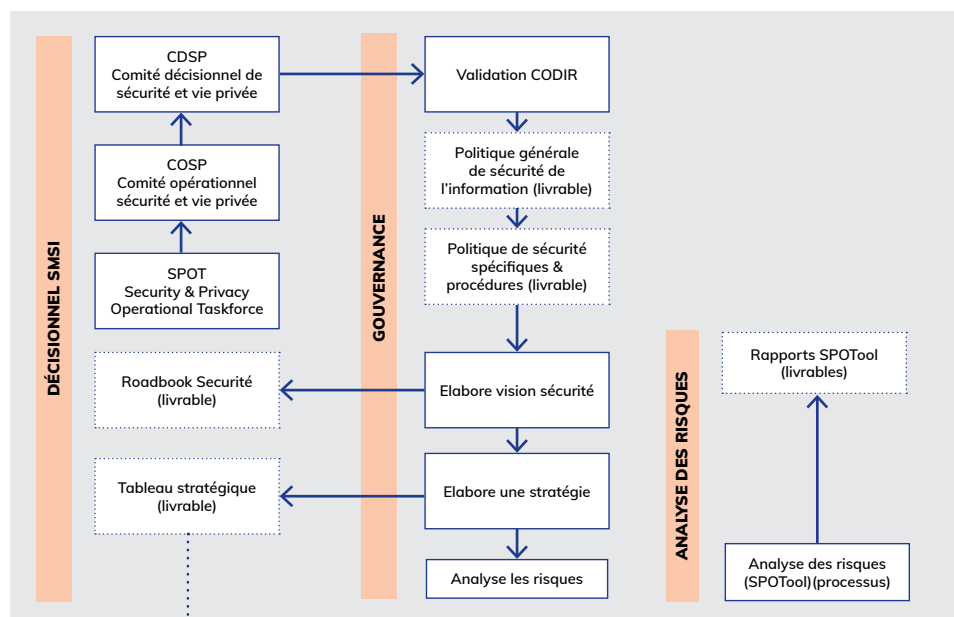
Le Otrust se traduit par une « non-confiance par défaut ». Historiquement, le périmètre était suffisant pour déterminer qui peut avoir accès ou qui ne peut pas avoir accès à un actif. L'idée était de protéger ce périmètre et de partir du principe que tout actif dans ce périmètre était protégé de manière équivalente à tous les autres actifs présents. Le modèle Otrust modifie ce principe en déclarant que le périmètre interne est par défaut non approuvé, entraînant une protection graduelle et spécifique à chaque actif. L'ETNIC considère aujourd'hui ce modèle comme indispensable pour faire face à :

- L'hybridation à venir, avec les solutions Cloud ;
- Le développement du BYOD (Bring Your Own Device) ;
- L'augmentation des menaces directes au niveau des utilisateurs (Phishing) ;
- Le principe de la donnée au centre des systèmes (Data Centric).

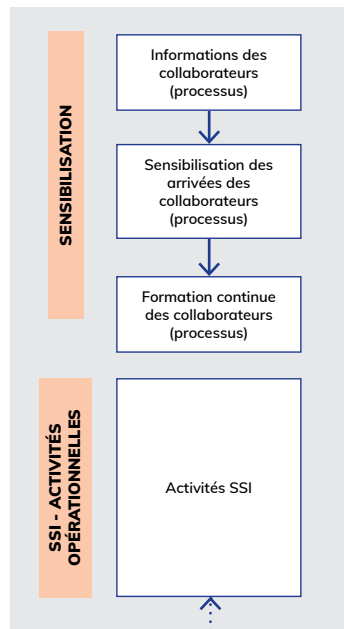
Le déploiement de l'approche Otrust est systématique et constitue les fondements de la stratégie de sécurité portée par l'ETNIC et décrite dans le Roadbook de sécurité.

Fonctionnement du SMSI de l'ETNIC

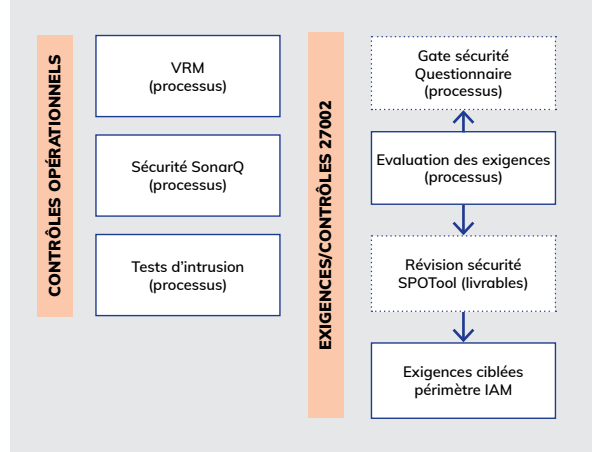
Plan



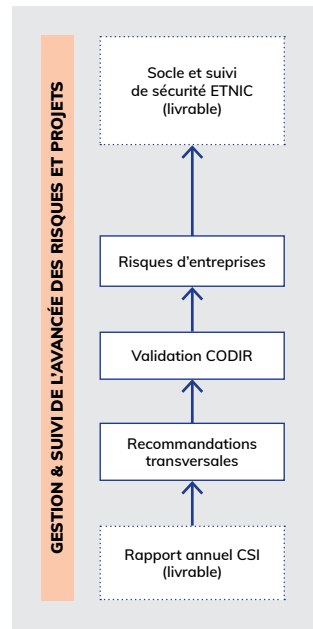
Do



Check



Act



Le Système de Management de la Sécurité de l'ETNIC est ici représenté de manière illustrée en reprenant les livrables, processus, et principales étapes de son fonctionnement. Ce schéma est donné à titre d'illustration et d'information. N'hésitez pas à contacter l'équipe SPOT pour de l'information supplémentaire sur le SMSI.



www.etnic.be